

CVE Report — Dependency Scan

Project: com.demo.supplychain:vulnerable-invoice-service:1.0.0 | **Scan date:** 2026-06-20 | **SHA:** 61ed8c3140d76e3a19a88954e834d39c9f7635fb | **Scanner:** dependency-risk-scanner v1.0 (Stage 1)

Supply-chain alert: Two structural issues were detected beyond individual CVEs — an HTTP-only Maven repository (`internal-untrusted-mirror`) susceptible to MITM artifact injection, and a typosquatted dependency coordinate (`com.fastxml.jackson.core`) that must be removed immediately.

Summary

Metric	Count
Total CVEs found	13
CRITICAL CVEs	4
HIGH CVEs	6
MEDIUM CVEs	3
LOW CVEs	1
Dependencies scanned	9
Dependencies with CVEs	5
Outdated dependencies	7
License violations	1
Supply-chain alerts	2

Supply-Chain Structural Issues

CRITICAL — Typosquatted dependency: `com.fastxml.jackson.core:jackson-databind:2.9.8` uses a groupId that omits `er` from the legitimate `com.fasterxml` namespace. This coordinate does not exist on Maven Central and is unresolvable. If a malicious actor publishes a JAR under this groupId to any accessible mirror, it becomes an arbitrary-code-execution vector at build time. **Remove this block from `pom.xml` immediately.**

HIGH — Insecure HTTP repository: Repository `internal-untrusted-mirror` is served at `http://insecure-mirror.example.net/maven2` over plain HTTP with no TLS. Any artifact retrieved from this host is susceptible to man-in-the-middle substitution. Maven 3.8+ blocks HTTP mirrors by default; remove this entry or replace it with a verified HTTPS endpoint.

Known-Vulnerable Dependencies

Dependency	Version	Top CVE	CVSS	Severity	Fix Version
org.apache.logging.log4j:log4j-core	2.14.1	CVE-2021-44228 (Log4Shell)	10.0	CRITICAL	2.17.1
org.apache.logging.log4j:log4j-api	2.14.1	CVE-2021-44228	10.0	CRITICAL	2.17.1
com.fasterxml.jackson.core:jackson-databind	2.9.8	CVE-2019-14379	9.8	CRITICAL	2.14.0
com.google.guava:guava	24.1.1-jre	CVE-2018-10237	5.9	MEDIUM	32.0.0-jre
commons-io:commons-io	2.4	CVE-2021-29425	4.8	MEDIUM	2.7

All CVEs

CVE	Dependency	CVSS	Severity	Type
CVE-2021-44228	log4j-core / log4j-api 2.14.1	10.0	CRITICAL	RCE via JNDI injection (Log4Shell)
CVE-2021-45046	log4j-core / log4j-api 2.14.1	9.0	CRITICAL	JNDI context lookup bypass (post-2.15.0 patch bypass)
CVE-2019-14379	jackson-databind 2.9.8	9.8	CRITICAL	RCE via unsafe deserialization / polymorphic typing
CVE-2019-14439	jackson-databind 2.9.8	7.5	HIGH	Information disclosure via logback-classic gadget
CVE-2020-36518	jackson-databind 2.9.8	7.5	HIGH	DoS via deeply nested JSON (StackOverflowError)
CVE-2022-42003	jackson-databind 2.9.8	7.5	HIGH	DoS via uncontrolled resource consumption
CVE-2022-42004	jackson-databind 2.9.8	7.5	HIGH	DoS via uncontrolled resource consumption in BeanDeserializer
CVE-2021-44832	log4j-core / log4j-api 2.14.1	6.6	MEDIUM	RCE via JDBC Appender with attacker-controlled config
CVE-2021-45105	log4j-core / log4j-api 2.14.1	5.9	MEDIUM	DoS via infinite recursion in log message processing
CVE-2018-10237	guava 24.1.1-jre	5.9	MEDIUM	Hash-flooding DoS via unbounded memory allocation
CVE-2019-12384	jackson-databind 2.9.8	5.9	MEDIUM	SSRF via H2 JDBC URL in embedded type handling
CVE-2021-29425	commons-io 2.4	4.8	MEDIUM	Partial path traversal in FilenameUtils.normalize()
CVE-2020-8908	guava 24.1.1-jre	3.3	LOW	Predictable temp dir creation via Files.createTempDir()

Outdated Dependencies (no active CVE)

Dependency	Current	Latest	Years Behind
org.apache.commons:commons-lang3	3.4	3.20.0	~9
mysql:mysql-connector-java	8.0.30	8.0.33	~1
org.junit.jupiter:junit-jupiter	5.10.2	6.1.0	~1

License Violations

Dependency	Version	License	Issue
mysql:mysql-connector-java	8.0.30	GPL-2.0	Copyleft license incompatible with permissive-only (Apache-2.0) project policy

Recommendation: Replace with `com.mysql:mysql-connector-j:8.0.31+` (GPL-2.0 with FOSS exception) or `org.mariadb.jdbc:mariadb-java-client` (LGPL-2.1).

Repository Configuration

Repository ID	URL	Protocol	Risk
central	https://repo.maven.apache.org/maven2	HTTPS	OK
internal-untrusted-mirror	http://insecure-mirror.example.net/maven2	HTTP	CRITICAL — MITM Risk

Machine-readable source: `depscan-report.json` . Ready for Stage 2 Risk Scoring and Stage 3 Auto-Remediation.